SECCIÓN 7.1

Rol de las herramientas en un SOC moderno

Temas de esta sección:

- Por qué las herramientas son indispensables en operaciones SOC
- Herramientas como fuentes de evidencia, no como verdad absoluta
- Qué puede automatizarse y qué sigue requiriendo criterio humano
- Diferencia entre detección, enriquecimiento y decisión
- Mini caso: misma alerta, distinta visibilidad según herramienta disponible

7.1 | Herramientas: apoyo operativo, no verdad absoluta

Lo que aportan las herramientas

- Visibilidad sobre endpoint, red, identidad, cloud y aplicaciones
- Velocidad para buscar, correlacionar y enriquecer eventos
- Consistencia mediante reglas, detecciones, playbooks y registros
- Trazabilidad: tickets, acciones y evidencia histórica
- Escalabilidad para trabajar grandes volúmenes de alertas

Lo que NO resuelven solas

- No conocen siempre el contexto de negocio
- No ven todo el entorno ni todas las fuentes
- Pueden generar falsos positivos o falsos negativos
- Pueden mostrar scores sin explicar evidencia suficiente
- No deberían tomar decisiones críticas sin validación humana

7.1 | De alerta a decisión: qué rol cumple cada capa

DETECCIÓN

La herramienta identifica una señal: regla, IOC, comportamiento, anomalía, reputación o modelo.

```
Ejemplo:
'Possible C2 Communication'
```

ENRIQUECIMIENTO

El sistema agrega contexto: reputación, geolocalización, hash, histórico, otros hosts, MITRE, riesgo.

```
Ejemplo:
dominio raro + score alto + 3
hosts.
```

DECISIÓN

El analista valida evidencia, contexto, impacto y limitaciones. Decide cerrar, monitorear, validar, escalar o contener.

```
La decisión no debe depender de un
único campo.
```

7.1 | Qué puede automatizarse y qué requiere criterio humano

Automatizable — tareas repetitivas y predecibles

- Consultar reputación de hash, dominio o IP
- Buscar un IOC en todos los endpoints
- Enriquecer alertas con contexto (MITRE, geoloc, primer visto)
- Abrir ticket con evidencia estructurada
- Notificar al equipo por mensaje automático
- Buscar actividad histórica del usuario o host
- Generar resumen inicial del caso
- Calcular criticidad del activo

Criterio: ¿siempre hace lo mismo con los mismos datos? → automatizable.

Requiere criterio humano — decisiones de impacto

- Decidir si aislar un servidor productivo
- Deshabilitar cuenta de servicio o ejecutiva
- Confirmar o descartar un incidente
- Interpretar evidencia contradictoria entre fuentes
- Evaluar impacto operativo de una acción
- Bloquear servicios cloud compartidos
- Comunicar a negocio o management
- Cerrar o escalar con evidencia incompleta

Criterio: ¿depende del contexto, activo o riesgo operativo? → humano.

7.1 | Mini caso: misma alerta, distinta visibilidad

La herramienta disponible define qué podés afirmar. La misma alerta puede verse muy distinta:

```
Alert: Suspicious PowerShell
Host: FIN-LAP-022  |  User: finanzas.paz  |  Action: Allowed

── CON SOLO SIEM ──
Alerta genérica sin process tree ni command line
Conclusión posible: ambigua

── CON EDR COMPLETO ──
WINWORD.EXE → powershell.exe -nop -w hidden -enc
update.exe creado en C:\Users\Public\
Conexión a billing-check-update.net cada 60s
Scheduled task: OneDriveUpdate
```

Preguntas para pensar:

- ¿Qué cambia si tenemos EDR completo?
- ¿Qué no podemos afirmar si solo vemos SIEM?
- ¿Qué fuente pedirías para completar el análisis?
- ¿Escalarías igual si el activo es crítico?
- ¿Qué información faltaría para cerrar?

Sin EDR: el analista ve una alerta genérica sin process tree. Con EDR: ve la cadena completa WINWORD→PS -enc→archivo en Public→conexión externa. La herramienta disponible define qué podés afirmar.